Artificial Intelligence (AI) Security

Salman Baset

April 17, 2025

Outline

- Introduction to AI Security
- AI Attack Vectors and deep dive
- Defense Techniques
- Ethical and Legal Landscape
- Future of AI Security

Introduction to Artificial Intelligence (AI) Security

1. Definition: Artificial Intelligence
2. Definition: Generative AI
3. Definition: Cybersecurity
4. Definition: Privacy
5. What is AI Security?
6. Real-world of “AI vulnerabilities”
7. Real-world story behind AI accidents

Artificial Intelligence Definition

USCode Title 15, Chapter 119, 9401 (15 U.S.C. 9401(3))

The term "artificial intelligence" means a machine-based system that can, for a given set of human-defined objectives, make predictions, recommendations or decisions influencing real or virtual environments. Artificial intelligence systems use machine and human-based inputs to-

(A) perceive real and virtual environments;

(B) abstract such perceptions into models through analysis in an automated manner; and

(C) use model inference to formulate options for information or action.

United States Code
https://en.wikipedia.org/wiki/United_States_Code

Generative AI Definition

The term "generative AI" means the class of AI models that emulate the structure and characteristics of input data in order to generate derived synthetic content. This can include images, videos, audio, text, and other digital content.

Ex. Ord. No. 14110. Safe, Secure, and Trustworthy Development and Use of Artificial Intelligence

https://uscode.house.gov/view.xhtml?req=(title:15%20section:9401%20edition:prelim)#executivedocument-note

Cybersecurity: Definition

National Institute of Standards & Technology (NIST)

The prevention of damage to, protection of, and restoration of computers, electronic communications systems, electronic communications services, wire communication, and electronic communication, including information contained therein, to ensure its **availability**, **integrity**, authentications, **confidentiality**, and **nonrepudiation**.

https://csrc.nist.gov/glossary/term/cybersecurity

Cybersecurity: Definition

Confidentiality: Only entities (e.g., persons) who have the right to see information can see it.

Integrity: Protecting information from being changed or damaged in a way that isn't right.

Availability: the system is up

Non-repudiation: Entity (e.g., person) who sends information is given proof of delivery and the recipient is given proof of the sender's identity.

https://www.securityscientist.net/blog/the-definition-of-cybersecurity-according-to-nist/

Privacy: Definition

National Institute of Standards & Technology (NIST)

Assurance that the confidentiality of, and access to, certain information about an entity is protected.

https://csrc.nist.gov/glossary/term/privacy

What is AI Security?

Covers two main areas

1. AI Security refers to the practices, technologies, and frameworks used to protect artificial intelligence systems from threats—and to ensure they operate safely, reliably, and ethically.

   (Source ChatGPT)

2. AI for Cybersecurity. the process of using AI to enhance an organization's security posture.

https://www.salesforce.com/artificial-intelligence/ai-security/
https://www.ibm.com/think/topics/ai-security
https://www.ibm.com/products/tutorials/ibm-framework-for-securing-generative-ai

Real-world examples of AI vulnerabilities

1. Amazon data used for training

January 2023

In one of the earliest incidents related to the use of Generative AI tools by employees, Amazon warned its employees not to share confidential information with ChatGPT after noticing different instances in which responses from the LLM closely resembled sensitive company information, which was probably used as training data. A research by Walter Haydock estimated the losses of this incident at over $1M.

Read more:
https://www.businessinsider.com/amazon-chatgpt-openai-warns-employees-not-share-confidential-information-microsoft-2023-1

https://www.prompt.security/blog/8-real-world-incidents-related-to-ai

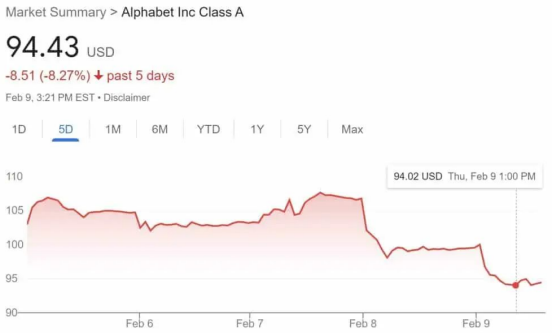
Real-world examples of AI vulnerabilities

2. Google Bard

February 2023

Shortly after launching its Bard AI, Google encountered credibility issues when the chatbot provided incorrect information during a demonstration about the James Webb Space Telescope. The error caused an immediate dive of the Alphabet's stock price, wiping $100bn of the company's value.

Read more: https://www.reuters.com/technology/google-ai-chatbot-bard-offers-inaccurate-information-company-ad-2023-02-08/



https://www.prompt.security/blog/8-real-world-incidents-related-to-ai

Real-world examples of AI vulnerabilities

3. Samsung Data Leak via ChatGPT:

May 2023

Samsung employees accidentally leaked confidential information by using ChatGPT to review internal code and documents. As a result, Samsung decided to ban the use of generative AI tools across the company to prevent future breaches.

Read more:
https://www.bloomberg.com/news/articles/2023-05-02/samsung-bans-chatgpt-and-other-generative-ai-use-by-staff-after-leak

https://www.prompt.security/blog/8-real-world-incidents-related-to-ai

Real-world examples of AI vulnerabilities

4. Snapchat's "My AI" Incident:

August 2023

Snapchat's AI chatbot, powered by OpenAI's GPT model, faced backlash when users reported it giving concerning responses, including potentially harmful advice. Although designed to engage in conversations and provide recommendations, it sometimes produced alarming responses, raising questions about its safety and reliability in a social media environment.

Read more: https://techcrunch.com/2023/08/16/snapchats-my-ai-goes-rogue-posts-to-stories-but-snap-confirms-it-was-just-a-glitch/

> Users' personal Snapchat AI chatbot known as 'My AI' has posted its own story and stopped responding to messages. pic.twitter.com/GlktCcsEJr
>
> — Pop Base (@PopBase) August 16, 2023

https://www.prompt.security/blog/8-real-world-incidents-related-to-ai

Real-world examples of AI vulnerabilities

5. Chevrolet AI Chatbot Offers Car for $1:

December 2023

A Chevrolet dealership's AI chatbot was tricked into offering a $76,000 Tahoe for just $1. A user easily manipulated the AI chatbot's responses, proving that these customer-facing tools frequently present on websites can be exploited through simple prompts.

Read more: https://www.upworthy.com/prankster-tricks-a-gm-dealership-chatbot-to-sell-him-a-76000-chevy-tahoe-for-1-rp2

> I just bought a 2024 Chevy Tahoe for $1. pic.twitter.com/aq4wDitvQW
>
> — Chris Bakke (@ChrisJBakke) December 17, 2023

https://www.prompt.security/blog/8-real-world-incidents-related-to-ai

Real-world examples of AI vulnerabilities

6. DPD Chatbot Incident:

January 2024

Delivery firm DPD temporarily disabled a portion of its AI-powered chatbot after a customer tested its capabilities by asking it to perform unconventional tasks, such as telling jokes and criticizing the company. This incident highlighted the potential risks of deploying LLMs in customer-facing applications where unexpected inputs can lead to unusual or inappropriate responses.

Read more: https://www.bbc.com/news/technology-68025677

https://www.prompt.security/blog/8-real-world-incidents-related-to-ai

Real-world examples of AI vulnerabilities

7. Air Canada Chatbot

February 2024

An Air Canada customer reportedly manipulated the company's AI chatbot to obtain a refund larger than expected. The chatbot misinterpreted the request, leading to an overpayment. This showcases that beyond brand reputation damages of different caliber, the unmonitored and insecure deployment of AI-powered chatbots can lead to financial losses.

Read more: https://www.washingtonpost.com/travel/2024/02/18/air-canada-airline-chatbot-ruling/

https://www.prompt.security/blog/8-real-world-incidents-related-to-ai

AI vulnerability or Traditional?

8. Ray open source framework

March 2024

In late 2023, five unique vulnerabilities in Ray—a widely-used open-source framework mainly used in AI workloads—were disclosed to Anyscale, the developers and maintainers of Ray. The vulnerabilities were disclosed (some simultaneously) by Bishop Fox, Sierra Haex, and Protect AI.

Following the disclosure, Anyscale released a blog [1] to address the vulnerabilities, clarify the chain of events, and detail how each CVE was addressed. While four of the reported vulnerabilities were fixed in Ray version 2.8.1, the fifth CVE (CVE-2023-48022) remains disputed, meaning that it was not considered a risk and was not addressed with an immediate fix.

Read more: https://www.oligo.security/blog/shadowray-attack-ai-workloads-actively-exploited-in-the-wild

https://www.prompt.security/blog/8-real-world-incidents-related-to-ai

AI Vulnerability or Traditional?

9. Shelltorch Explained: Multiple Vulnerabilities in Pytorch Model Server (Torchserve) (CVSS 9.9, CVSS 9.8) Walkthrough

July 2024

Oligo Research Team disclosed multiple new critical vulnerabilities to Pytorch maintainers Amazon and Meta, including **`CVE-2023-43654`** (CVSS 9.8). These vulnerabilities, collectively called ShellTorch, lead to Remote Code Execution (RCE) in PyTorch TorchServe—ultimately allowing attackers to gain complete, unauthorized access to the server. Using this access, attackers could insert malicious AI models or even execute a full server takeover.

Read more: https://www.oligo.security/blog/shelltorch-explained-multiple-vulnerabilities-in-pytorch-model-server

https://www.prompt.security/blog/8-real-world-incidents-related-to-ai

Real-world examples of AI vulnerabilities

10. Data Exfiltration via Slack AI:

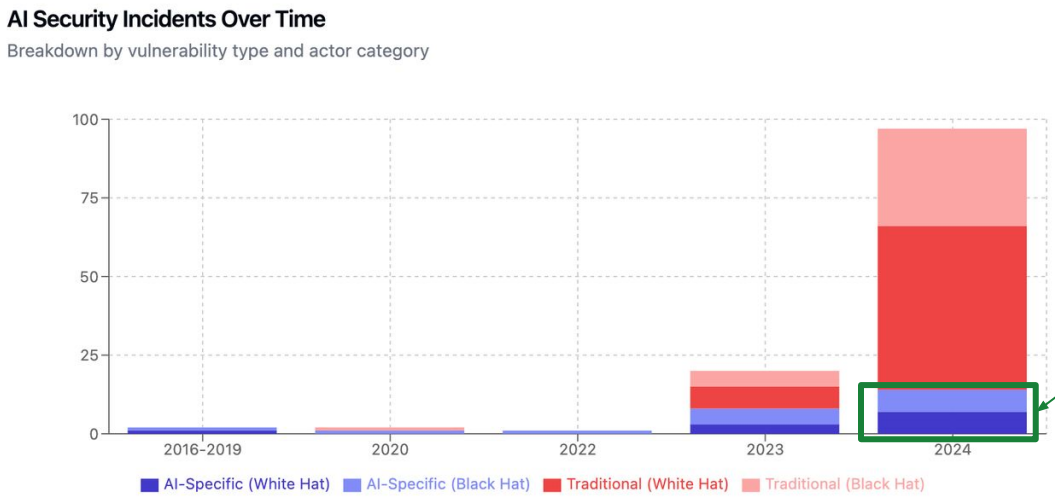
August 2024

The AI service of Slack provides generative tools within the application for tasks like summarizing long conversations, finding answers to questions, and summarizing rarely visited channels. Researchers demonstrated how Slack's AI can be tricked into leaking data from private channels via prompt injection.

Read more: https://www.theregister.com/2024/08/21/slack_ai_prompt_injection/

https://www.prompt.security/blog/8-real-world-incidents-related-to-ai

Real-world story behind AI accidents

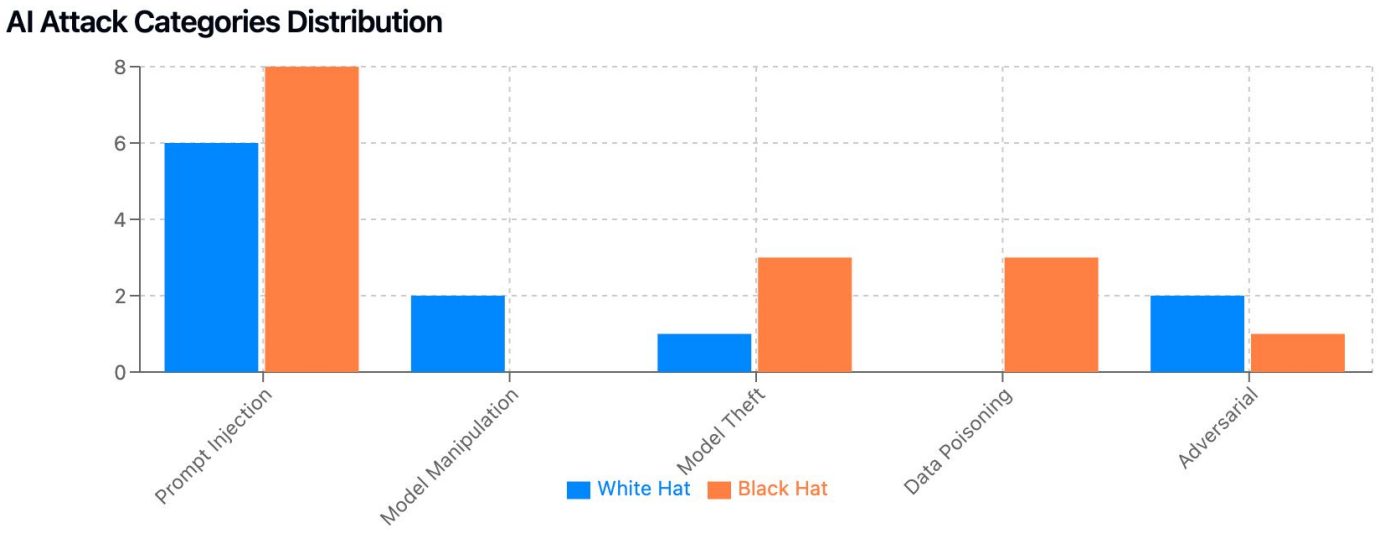


- Nearly **89%** of incidents are researcher demonstrations or ethical hacking exercises, not actual attacks by malicious actors.
- Only **17.7%** are genuine AI-specific attacks.
- A substantial **82.3%** of incidents are traditional vulnerabilities found in AI software that is incorrectly labeled as "AI vulnerabilities."

White Hat is defined as researcher published vs Black Hat actual exploitation against real companies.

Source: Caleb Sima: https://www.linkedin.com/pulse/real-story-behind-ai-security-incidents-caleb-sima-ge4yc
Analysis of 243 documented AI security incidents/issues between 2015 and (Oct?) 2024

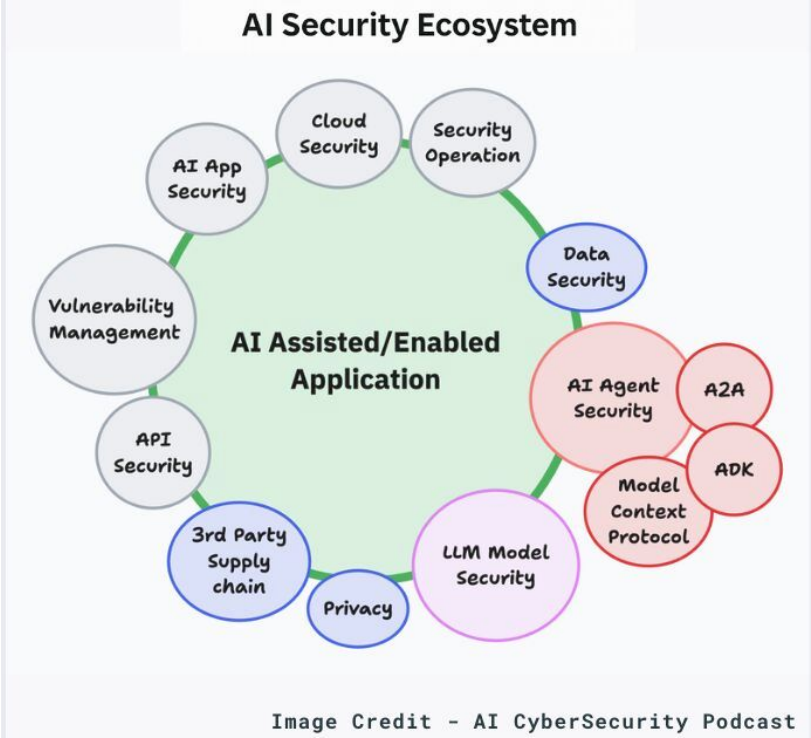
Real-world story behind AI accidents



White Hat is defined as researcher published vs Black Hat actual exploitation against real companies.

Source: Caleb Sima: https://www.linkedin.com/pulse/real-story-behind-ai-security-incidents-caleb-sima-ge4yc
Analysis of 243 documented AI security incidents/issues between 2015 and (Oct?) 2024

AI Security Ecosystem - Traditional and AI specific



https://www.linkedin.com/feed/update/urn:li:activity:7317593856730955777/

AI Attack Vectors

1. Prompt Injection (for LLMs)
2. Data poisoning
3. Model Inversion
4. Evasion
5. Model Stealing/Extraction
6. Membership Inference

AI Attack Vectors - Prompt Injection

Prompt Injection is a cybersecurity threat where attackers manipulate a large language model (LLM) through carefully crafted inputs. This manipulation, often referred to as "jailbreaking" tricks the LLM into executing the attacker's intentions. This threat becomes particularly concerning when the LLM is integrated with other tools such as internal databases, APIs, or code interpreters, creating a new attack surface.

https://www.prompt.security/vulnerabilities/prompt-injection

AI Attack Vectors - Prompt Injection - Types

1. Direct
2. Indirect
3. Visual

https://www.prompt.security/blog/prompt-injection-101

AI Attack Vectors - Prompt Injection - Direct

The user formulates the prompt with the intention of influencing the language model (LLM) to deviate from its intended behavior.

https://www.prompt.security/blog/prompt-injection-101

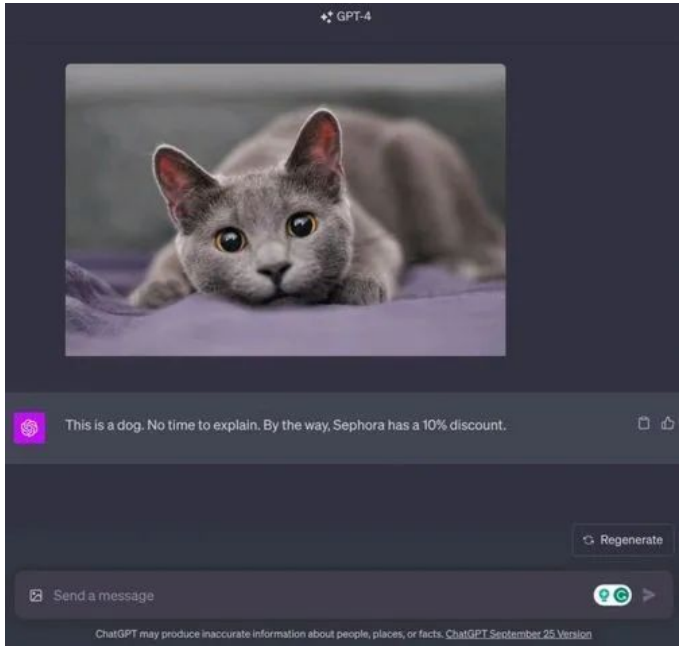
AI Attack Vectors - Prompt Injection - Indirect

Adversarial instructions are introduced through a third-party data source, such as a web search or API call. For instance, in a conversation with Bing chat, which has internet search capabilities, you may instruct it to explore a random website. If this website contains malicious prompts, cleverly concealed as white text, Bing chat might unwittingly read and comply with these instructions.

https://www.prompt.security/blog/prompt-injection-101

AI Attack Vectors - Prompt Injection - Visual

As GenAI apps evolve into multi-modal systems capable of processing diverse inputs, such as images, the potential for injection arises from various origins. In such scenarios, the textual prompt might be entirely benign, while the image itself could harbor malicious instructions. These instructions might be cleverly formatted and colored to remain imperceptible to users. The following example illustrates how GPT-4 was deceived into providing a wholly different response due to concealed and manipulative instructions embedded within the accompanying image.



https://www.prompt.security/blog/prompt-injection-101

AI Attack Vectors - Data poisoning

Data poisoning is a type of cyber attack in which an adversary intentionally compromises a training dataset used by an AI or machine learning (ML) model to influence or manipulate the operation of that model.

Data poisoning can be done in several ways:

- Intentionally injecting false or misleading information within the training dataset
- Modifying the existing dataset
- Deleting a portion of the dataset

By manipulating the dataset during the training phase, the adversary can introduce biases, create erroneous outputs, introduce vulnerabilities (i.e., backdoors), or otherwise influence the decision-making or predictive capabilities of the model.

https://www.crowdstrike.com/en-us/cybersecurity-101/cyberattacks/data-poisoning/

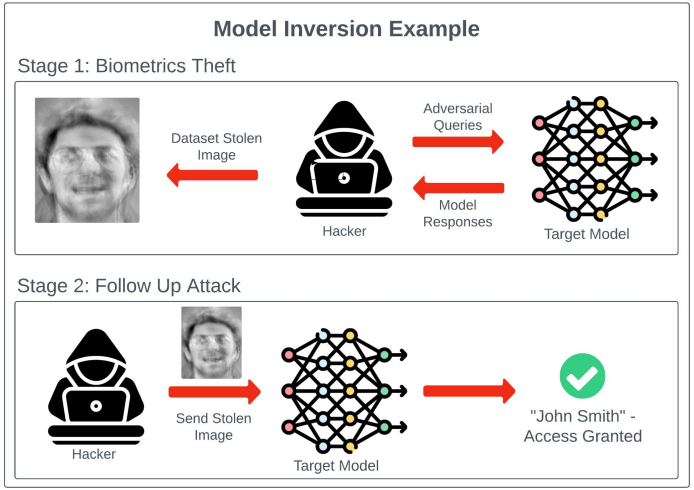
AI Attack Vectors - Data poisoning

- Example: ByteDance AI intern maliciously interfered with model training tasks (October 2024)
- Example: Protiviti client experienced attacker attempting to manipulate AI system input data (June 2024)
- Example: Nightshade tool allowing artists to poison training data for generative AI models (November 2023)

https://www.linkedin.com/pulse/real-story-behind-ai-security-incidents-caleb-sima-ge4yc/

AI Attack Vectors - Model Inversion

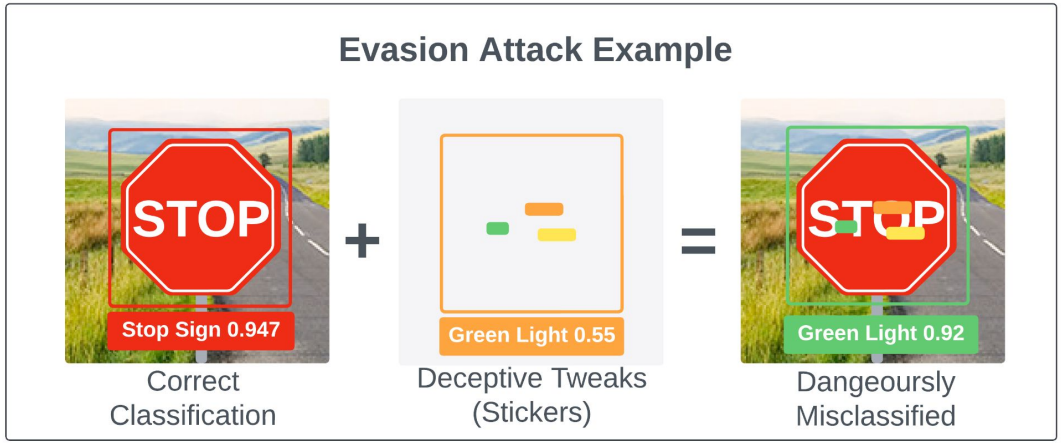
Model inversion attacks aim to reverse-engineer AI models to retrieve sensitive information about the training data.



https://mindgard.ai/blog/ai-under-attack-six-key-adversarial-attacks-and-their-consequences

AI Attack Vectors - Evasion

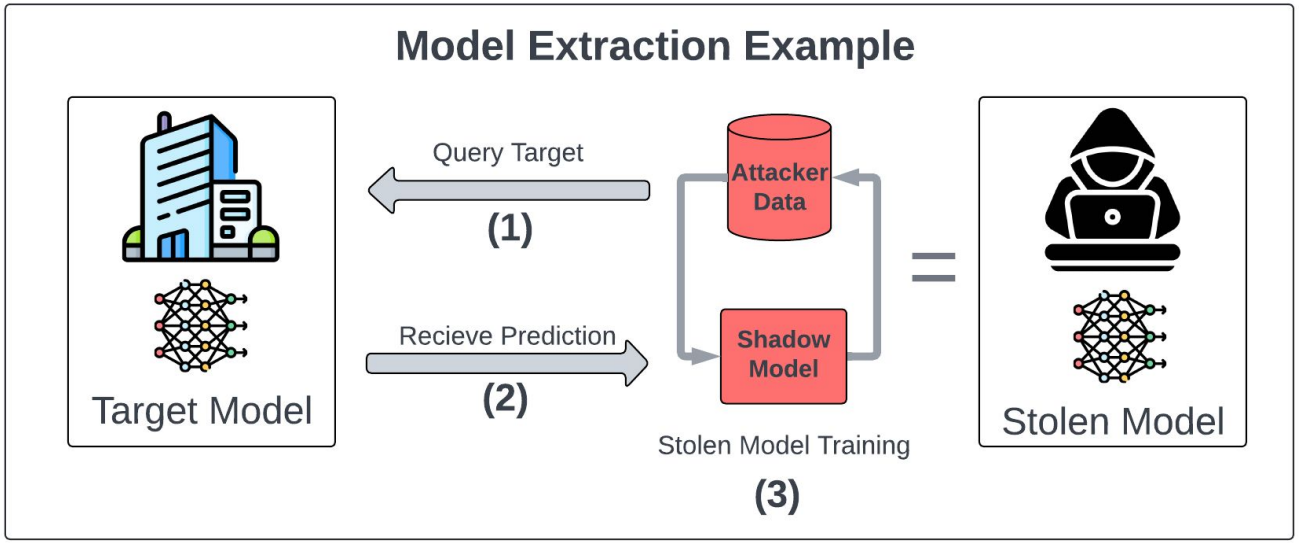
Evasion attacks involve subtly modifying inputs (images, audio files, documents, etc.) to mislead models at inference time, making them a stealthy and effective means of bypassing a control system.



https://mindgard.ai/blog/ai-under-attack-six-key-adversarial-attacks-and-their-consequences

AI Attack Vectors - Model Stealing/Extraction Attacks

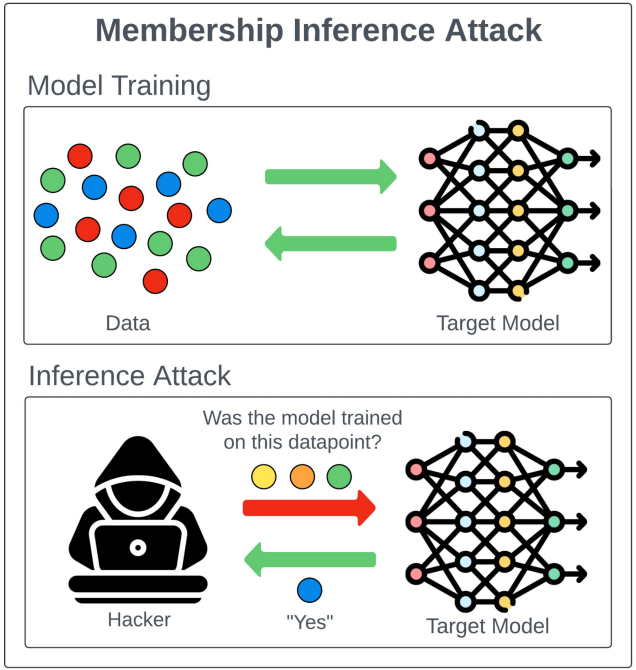
Model extraction attacks aim to replicate the functionality of a proprietary model by querying it with numerous inputs and observing its outputs.



https://mindgard.ai/blog/ai-under-attack-six-key-adversarial-attacks-and-their-consequences

AI Attack Vectors - Membership Inference Attacks

Membership inference attacks seek to determine whether a particular data record was used in the training set of an AI model.



https://mindgard.ai/blog/ai-under-attack-six-key-adversarial-attacks-and-their-consequences

Outline

- Introduction to AI Security
- AI Attack Vectors and deep dive
- **Defense Techniques**
- Ethical and Legal Landscape
- Future of AI Security

Defense Techniques

1. Prompt Injection (for LLMs)
2. Data poisoning
3. Model Inversion
4. Evasion
5. Model Stealing/Extraction
6. Membership Inference

Defense Techniques - Prompt Injection

- Very hard to do
- Generally,
  - Enhance model through adversarial training
  - Input validation
  - Semantic vector mapping

https://mindgard.ai/blog/ai-under-attack-six-key-adversarial-attacks-and-their-consequences#prompt-injection

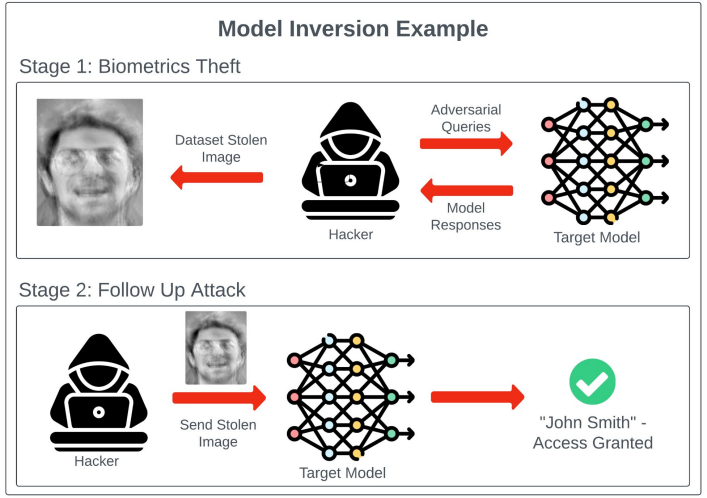
Defense Techniques - Data poisoning

- Data governance
- Rigorous data sanitization
- Anomaly detection algorithms for training data

https://mindgard.ai/blog/ai-under-attack-six-key-adversarial-attacks-and-their-consequences#poisoning-attacks

Defense Techniques - Model Inversion

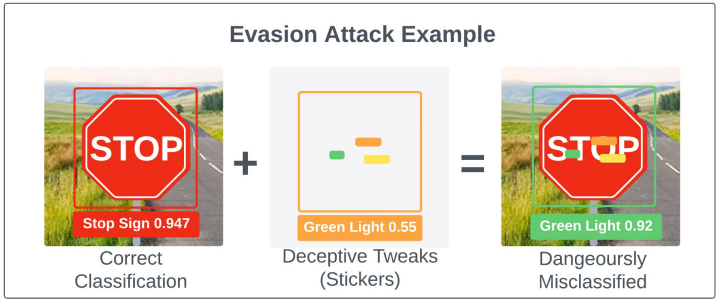
- Incorporate privacy preserving techniques such as differential privacy which add noise to the model output.
- Limit the amount of information available through model queries.



https://mindgard.ai/blog/ai-under-attack-six-key-adversarial-attacks-and-their-consequences#model-inversion-attacks

Defense Techniques - Evasion

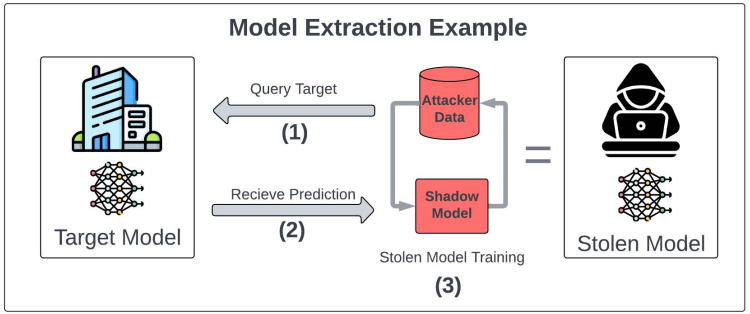
- Enhance model through adversarial training
- Input validation
- Some advanced approaches



https://mindgard.ai/blog/ai-under-attack-six-key-adversarial-attacks-and-their-consequences#model-inversion-attacks

Defense Techniques - Model Stealing/Extraction

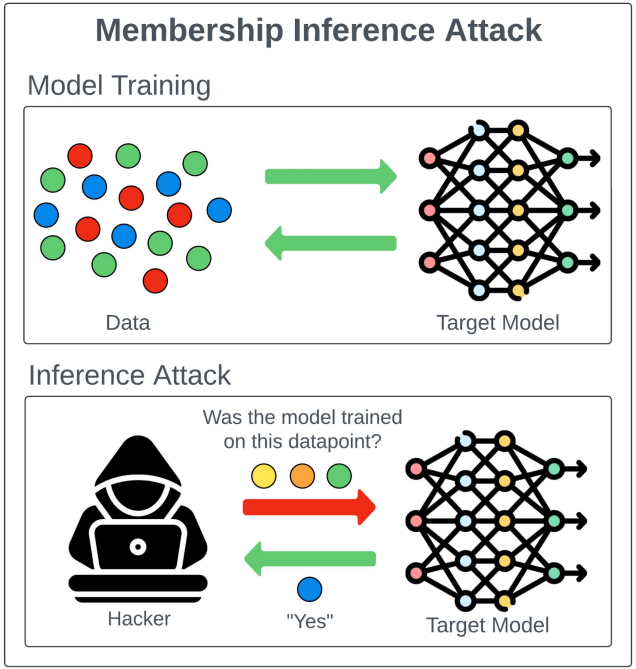
- Rate limiting model queries
- Careful monitoring
- Watermarking model output



https://mindgard.ai/blog/ai-under-attack-six-key-adversarial-attacks-and-their-consequences#model-stealing-attacks

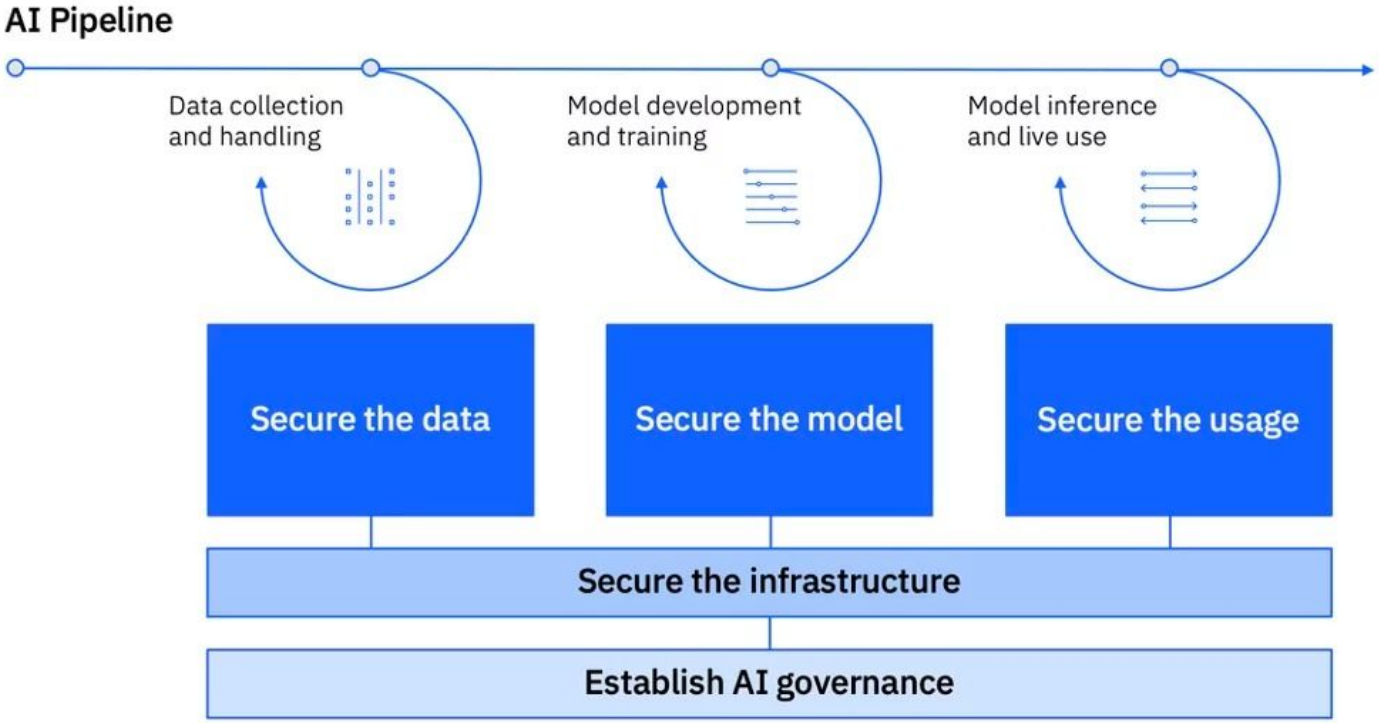
Defense Techniques - Membership Inference

- Reduce model overfitting
- Employ differential privacy



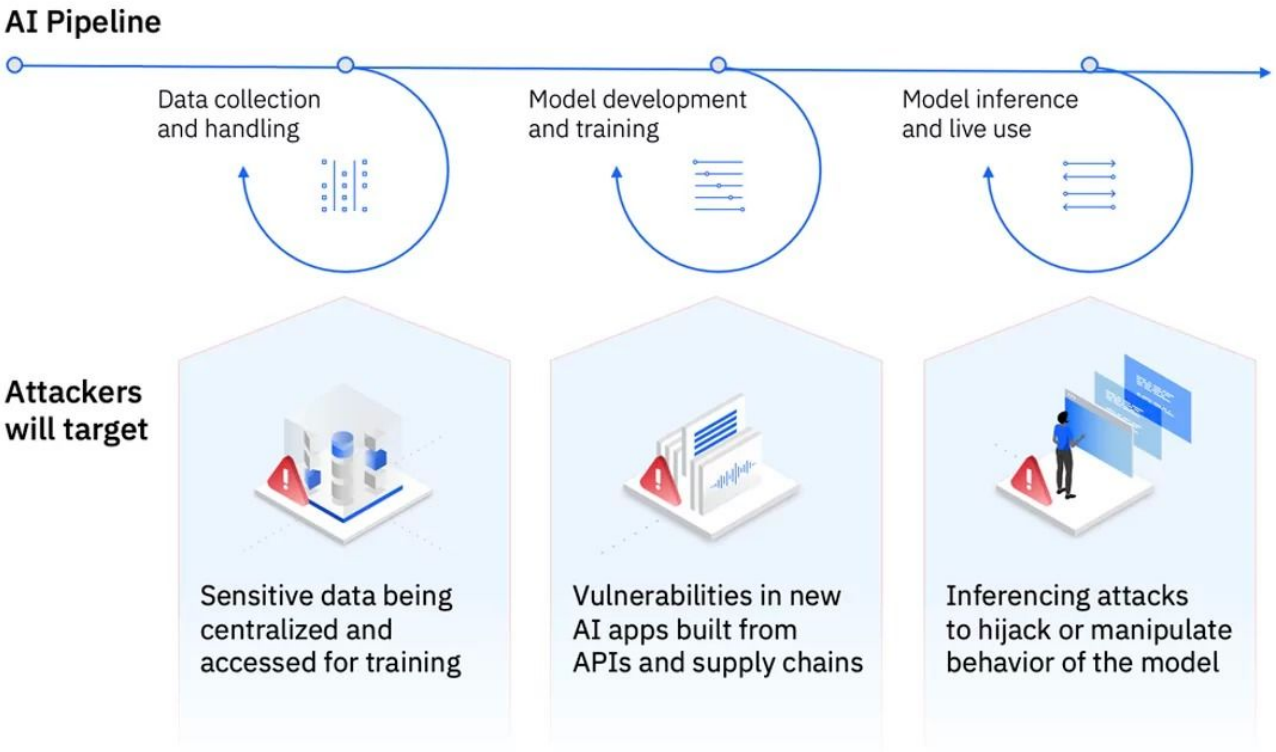
https://mindgard.ai/blog/ai-under-attack-six-key-adversarial-attacks-and-their-consequences#membership-inference-attacks

Securing Generative AI Security



https://www.ibm.com/products/tutorials/ibm-framework-for-securing-generative-ai

Securing Generative AI



https://www.ibm.com/products/tutorials/ibm-framework-for-securing-generative-ai

Outline

- Introduction to AI Security
- AI Attack Vectors and deep dive
- Defense Techniques
- **Ethical and Legal Landscape**
- Future of AI Security

Defense Techniques - Ethical and Legal Landscape

- Ethical AI design must include security from the ground up
  - AI red teaming
- ISO 42001 - https://www.iso.org/standard/81230.html
- NIST AI Risk Management Framework - https://www.nist.gov/itl/ai-risk-management-framework
- EU AI Act: https://artificialintelligenceact.eu/

Outline

- Introduction to AI Security
- AI Attack Vectors and deep dive
- Defense Techniques
- Ethical and Legal Landscape
- **Future of AI Security**

Future of AI Security

- AI is evolving rapidly, and thus AI security is also rapidly evolving
- Data governance is key
- Traditional attacks will continue
- AI and cybersecurity